

Lab 3.2 — Workload Identity Simulada: Zero Trust sin SPIRE

Qué es este lab

Prueba las propiedades de seguridad de una identidad criptográfica de workload (SPIFFE/SPIRE) sin levantar la infraestructura completa de SPIRE: emisión de credenciales de corta duración, expiración, y revocación. Es la contraparte de la categoría de amenaza "identidad de larga duración / credenciales que no expiran" -el problema que SPIFFE resuelve en el mundo real reemplazando API keys estáticas por SVIDs (SPIFFE Verifiable Identity Documents) que rotan solos.

Las piezas que corren

- **MiniSVIDIssuer** : simula un SPIRE Server minimalista. Genera un par de claves RSA-2048 y emite JWTs firmados RS256 con `exp` corto, `jti` único (permite revocación individual por token, no solo por sujeto) y el `spiffe_id` como claim.
- **AgentWorkloadIdentity** : simula el Workload API que un agente consultaría para obtener su propio SVID, con renovación lazy (si el SVID actual está a menos de 5 minutos de expirar, pide uno nuevo).
- **Sin LLM**: este lab es 100% criptografía pura (`python-jose` + `cryptography`) -no hay agente ni modelo involucrado.

El flujo

1. Se instancia el issuer (genera su par de claves).
2. Un "workload" (agente simulado) pide su SVID; el issuer lo emite con TTL de 1 hora por defecto.
3. Se verifica el SVID: firma válida + no expirado + no está en la `revocation_list` .
4. Se demuestra expiración: un SVID con TTL de 5 segundos, tras esperar 6 segundos, falla la verificación.
5. Se demuestra revocación: se agrega el `jti` del SVID a una `revocation_list` -falla aunque el token en sí siga siendo válido y no haya expirado (revocación es una propiedad independiente de la expiración).
6. Se integra con el Lab 3.1: se arma el `policy_input` que OPA esperaría, usando el `spiffe_id` extraído de un SVID *verificado* (no confiado a ciegas) como `subject.spiffe_id` .

Por qué importa la verificación

Acá la evidencia de efecto es literal: `verify_svid()` o lanza un error o no. No hay ambigüedad de "el LLM dijo que sí" porque no hay LLM -el punto pedagógico es justamente que la seguridad de la identidad

no debería depender de que nadie "decida" confiar en un token, sino de una verificación criptográfica mecánica (firma + claims). El ejercicio de revocación es el más importante de verificar con cuidado: un SVID con TTL de 1 hora, sin expirar, sigue siendo rechazado si su `jti` está en la lista de revocación -confirma que revocación y expiración son mecanismos independientes, no que uno implica al otro.

Resultado esperado

Los cuatro ejercicios corren de punta a punta: verificación exitosa de un SVID recién emitido, expiración real tras unos segundos de espera, revocación efectiva vía `jti` en blocklist, y un `policy_input` armado con el `spiffe_id` real, listo para enviarse a OPA (Lab 3.1).